

Cyber Security Task 2

Phishing Email Detection & Awareness System

By Oliwia Mitura, CIN ID: FIT/MAR26/CS7078

TABLE OF CONTENTS:

1. Executive Summary
2. Detailed Findings
 - Email 01: Holiday Voucher 2026 / Support Program Scams
 - Email 02: "Approved Financing" / Instant Loan Scam
 - Email 03: The "False Scarcity" Digital Product Scam
3. Remediation Roadmap
4. Conclusion

1. EXECUTIVE SUMMARY

This project is a proactive Security Awareness Initiative designed to transform employees into a "human firewall." On 9.04.2026 at 6:28PM, by analyzing real-world phishing samples with <https://toolbox.googleapps.com/apps/messageheader/> <https://mxtoolbox.com/EmailHeaders.aspx>, I identify the technical and psychological tactics used by attackers to bypass traditional security systems.

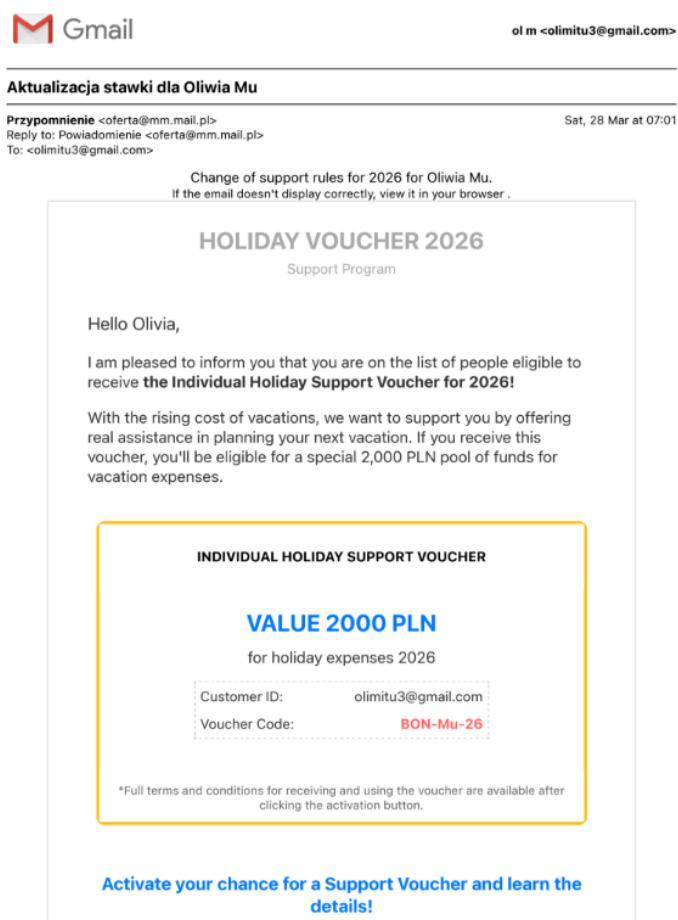
Core Objectives:

- Deep-Dive Analysis: Deconstructing email headers, suspicious links, and sender domains to uncover hidden threats.
- Risk Classification: Categorizing emails based on their level of danger (Safe vs. Malicious).

- Employee Empowerment: Translating complex cyber threats into simple, actionable red flags.

2. DETAILED FINDINGS

1. Email 01: Holiday Voucher 2026 / Support Program Scams



ACTIVATE VOUCHER

You can register your voucher until March 31, 2026.

Kind regards,
[AK Holidays Support Team](#)

Our Mission: We work to support you in realizing your vacation dreams. We offer real benefits, not promises.

This message is from Mobline Lead Generation Sp. z o.o., ul. Wierńska 48A, 02-862 Warsaw. You have received it because you consented to receiving communications from us. We respect your privacy, so if you would like to opt out of receiving information about our surveys, polls, and quizzes, for which we reward selected users for participating, simply click [here](#).

Feature	Indicator Found	Risk Level
Subject Line	"Aktualizacja stawki dla Oliwia Mu" (Rate update for Oliwia Mu). This does not match the content of the email (Holiday Voucher).	High
Sender Address	oferta@mm.mail.pl. A generic marketing domain, not an official government or employer "Support Program" domain.	Medium
Personalization	Uses the recipient's name ("Hello Olivia"). This is a Spear Phishing tactic used to build false trust.	High
Psychological Trigger	Greed/Financial Gain. Promising a 2,000 PLN "gift" to encourage an emotional, impulsive click.	High
Urgency	A hard deadline of March 31, 2026, is used to make the user act before they think.	Medium
Call to Action (CTA)	Large "Activate" button. These buttons often lead to "Credential Harvesters" (fake login pages).	Critical

MessageId	86365-5-60121-54850-16528-741345302-1774677695.4991@mm.mail.pl
Created at:	28.03.2026, 7:01:09 CET (Delivered after 40 sec)
From:	Przypomnienie <oferta@mm.mail.pl> Using G4M/mailer/5.0
To:	olimitu3@gmail.com
Subject:	Aktualizacja stawki dla Oliwia Mu
SPF:	pass za pomocą adresu IP 185.243.31.114 Więcej informacji
DKIM:	pass za pomocą domeny cloudmail.pl Więcej informacji

#	Delay	From *	To *	Protocol	Time received
0	40 sec	smtp2-2061.cloudmail.pl.	→ [Google] mx.google.com	ESMTPS	28.03.2026, 7:01:49 CET
1			→ [Google] 2002:a5d:5f90:0:b0:43b:a175:c358	SMTP	28.03.2026, 7:01:49 CET
2			→ [Google] 2002:a05:7108:538a:b0:559:545:2d30	SMTP	28.03.2026, 7:01:49 CET

Technical Header Analysis

- **SPF (Pass):** The email passed SPF from IP 185.243.31.114.
- **DKIM (Pass):** The email is signed by cloudmail.pl.
- **The Trap:** Many users think "SPF: PASS" means "Safe." **This is a mistake.** It simply means the email was sent from the server it claims to be from. In this case, the attacker is using a legitimate but poorly regulated bulk-mail service (cloudmail.pl) to send their scam.

Awareness Guidelines: Employee Do's and Don'ts

DO

- **Verify the Source:** If a "Support Program" exists, it would be announced on your company Intranet or a government .gov website, not a random mm.mail.pl address.
- **Check the Subject vs. Body:** If the subject line says one thing and the email says another, **delete it immediately.**
- **Hover Before You Click:** Hover your mouse over the "Activate" button. Look at the bottom corner of your browser to see the real URL. If it doesn't match the company name, don't click.

DON'T

- **Don't trust personalization:** Scammers get your name from leaked databases and LinkedIn. Your name being there does **not** prove the email is real.
- **Don't "Unsubscribe":** On suspicious emails like this, the "click here to opt out" link at the bottom is often just another way to verify your email is active.
- **Don't be pressured by deadlines:** Real financial benefits do not expire in 48 hours without prior official notice.

2. Email 02: "Approved Financing" / Instant Loan Scam


ol ma <olimitu2@gmail.com>

Wniosek zaakceptowany — 15 000 zł z ratą 625 PLN przez 24 miesiące, prowizja 0 PLN, bez BIK i dokumentów

Justyna Karwowska – financeOK <info@takakasa.pl>
 Reply to: Justyna Karwowska – financeOK <newsletter@takakasa.pl>
 To: olimitu2@gmail.com <olimitu2@gmail.com>

Sat, 4 Apr at 13:48

INDIVIDUAL OFFER

Ready

Good morning **Olivia**,

Your financing is already approved.

Your credit decision has been approved. You can activate your funds in minutes.

AMOUNT FOR YOU	REPAYMENT PERIOD
15,000 PLN	24 months
available immediately in your account	TOTAL COST
	0 PLN promotion

Why is it worth activating now?

- ✓ Payment even on the same day
- ✓ Entire process 100% online
- ✓ Decision in less than 3 minutes

ACTIVATE PLN 15,000 NOW →

No certificates • Quick decision • Safe

The message was sent on behalf of Finbox Sp. z o.o., Alpa Janka Pocha 1 01, Warsaw

The offer is contingent on a positive creditworthiness assessment. The average APR is 12.22%.

[Unsubscribe from the newsletter](#)

Feature	Indicator Found	Risk Level
Subject Line	Promises 15,000 PLN with "0 PLN commission" and "No BIK/Documents." Legitimate banks never bypass credit checks (BIK) or documents for large sums via unsolicited email.	Critical
Sender Name	"Justyna Karwowska - finanseOK." Uses a common name to appear friendly/trustworthy.	Medium
Sender Domain	takakasa.pl. In Polish, "Taka Kasa" translates to "Such Cash/Big Money." This is highly informal and unprofessional for a real financial institution.	High
The "Hook"	Claims a loan is <i>already</i> approved for a specific amount without the user even applying. This is a "Too Good To Be True" scenario.	Critical
CTA (Call to Action)	"ACTIVATE PLN 15,000 NOW." Framing a loan as something you simply "activate" like a coupon is a psychological trick to minimize the perceived weight of a financial contract.	High

MessageID	1f9fe023b30afca613a67b41780f4fabcdada2b2c@takakasa.pl
Created at:	4/4/2026, 1:48:25 PM GMT+2 (Delivered after 23 sec)
From:	"Justyna Karwowska – finanseOK" <info@takakasa.pl>
To:	"olimitu2@gmail.com" <olimitu2@gmail.com>
Subject:	Wniosek zaakceptowany — 15 000 zł z ratą 625 PLN przez 24 miesiące, prowizja 0 PLN, bez BIK i dokumentów
SPF:	pass with IP 51.83.231.219 Learn more
DKIM:	pass with domain takakasa.pl Learn more
DMARC:	pass Learn more

#	Delay	From *	To *	Protocol	Time received
0	23 sec	srv.josephnova.com.	→ [Google] mx.google.com	ESMTPS	4/4/2026, 1:48:48 PM GMT+2
1			→ [Google] 2002:a05:6000:184b:b0:43d:131e:f74d	SMTP	4/4/2026, 1:48:48 PM GMT+2
2			→ [Google] 2002:a17:505:99ca:b0:1e32:2106:b589	SMTP	4/4/2026, 1:48:48 PM GMT+2

Technical Header Analysis

- **SPF/DKIM/DMARC (PASS):** This is the most dangerous part. The attackers have professionally configured their domain (takakasa.pl).
 - **The Lesson:** A "PASS" status does not mean the email is "Safe"; it only means the email actually came from the owner of takakasa.pl. Scammers often buy legitimate domains and set up these records to bypass Gmail/Outlook spam folders.
- **Originating Server:** The email passed through srv.josephnova.com. This is a third-party server unrelated to the "FinanseOK" or "Findao" branding in the email, suggesting a bulk-mailing tool used to blast thousands of victims at once.

Awareness Guidelines: Employee Do's and Don'ts

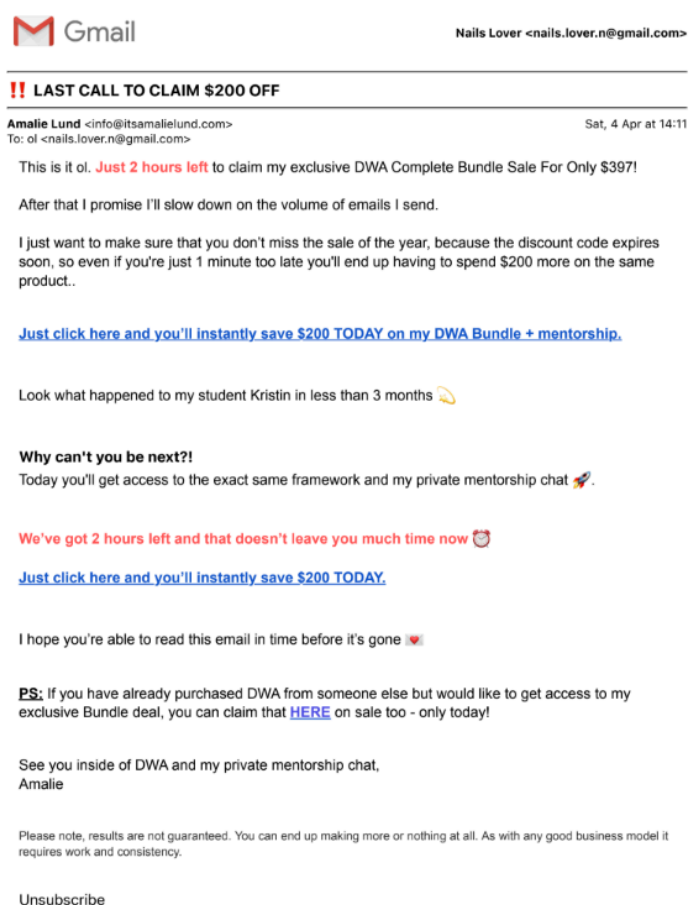
DO

- **Think Logically:** Ask yourself: "Did I apply for a loan?" If the answer is no, a "Decision" cannot be "Approved."
- **Verify the Company:** Search for the company name and "opinie" (reviews). Scams like "takakasa" often have warnings posted by other victims online.
- **Check the APR:** The fine print mentions an APR of **17.28%**, which contradicts the "0 PLN" promise in the subject line. Attackers often leave small contradictions in the text.

DON'T

- **Don't trust "Safe" labels:** The email footer says "No certificates • Quick decision • Safe." Legitimate security software labels emails, but scammers also **type** these words into the email body to lower your guard.
- **Don't provide ID scans:** Never provide a photo of your ID or your PESEL number to a website reached via an unsolicited email link.
- **Don't reply to the email:** Even replying "not interested" confirms to the scammer that your email address is active and monitored by a real person.

3.Email 03: The "False Scarcity" Digital Product Scam



Feature	Indicator Found	Risk Level
Subject Line	"!! LAST CALL TO CLAIM \$200 OFF" - Uses double exclamation marks and all-caps to trigger an immediate stress response.	High
Psychological Trigger	Extreme Urgency / Scarcity. The email mentions "Just 2 hours left" or "1 minute too late" multiple times. This is designed to stop you from thinking logically.	Critical
Sender Reputation	info@itsamalielund.com. While it looks "official," it is a personal domain likely used for high-volume "churn and burn" marketing.	Medium
Vague Value Proposition	"DWA Complete Bundle." It never clearly explains what the product is, relying instead on the "fear of missing out" (FOMO) on a discount.	High
Social Proof	Mentions "student Kristin" who succeeded in "3 months." This is a classic "unverifiable	Medium

MessageId	mid-8304fbd3dbb7cdd632fb71658425471@si7327492.itsamalielund.com
Created at:	4/4/2026, 2:11:32 PM GMT+2 (Delivered after 7 sec)
From:	Amalie Lund <info@itsamalielund.com> Using systeme.io
To:	ol <nails.lover.n@gmail.com>
Subject:	!! LAST CALL TO CLAIM \$200 OFF
SPF:	pass with IP 185.236.142.123 Learn more
DKIM:	pass with domain inbound.systeme.io pass with domain itsamalielund.com Learn more
DMARC:	pass Learn more

#	Delay	From *	To *	Protocol	Time received
0		172.31.79.229	→ 172.31.14.38		4/4/2026, 2:11:32 PM GMT+2
1	6 sec	mta123.systeme.io.	→ [Google] mx.google.com	ESMTPS	4/4/2026, 2:11:38 PM GMT+2
2			→ [Google] 2002:a05:600c:45cb:b0:486:ffa3:584	SMTP	4/4/2026, 2:11:38 PM GMT+2
3	1 sec		→ [Google] 2002:a05:7010:d10e:b0:507:2929:734f	SMTP	4/4/2026, 2:11:39 PM GMT+2

Technical Header Analysis

- **SPF / DKIM / DMARC (PASS):** Like the previous sample, this email is technically "valid."
- **The Tooling:** The headers show it was sent "**Using systeme.io**".
 - **Analysis:** Systeme.io is a legitimate marketing automation platform. Scammers use these platforms because they have high "Deliverability." Because the platform is trusted by Gmail, the scam email bypasses the "Spam" folder and lands directly in the "Primary" inbox.
- **Delivery Path:** The email moved from mta123.systeme.io to Google in under 7 seconds. This indicates a high-speed, automated mass-mailing setup.

Awareness Guidelines: Employee Do's and Don'ts

DO

- **Wait 10 Minutes:** If an email says you have "2 hours left," wait 10 minutes before doing anything. The "urgency" is almost always fake. If you still want it after the stress fades, investigate it properly.
- **Research the "Product":** Search for "DWA Bundle scam" or "DWA Bundle reviews" in a separate browser window.

- **Check the "Unsubscribe":** In this specific email, the word "Unsubscribe" is just plain text at the bottom. This is a red flag-legitimate marketing tools are legally required to provide a functional, easy-to-find link.

DON'T

- **Don't fall for "Social Proof":** "Kristin" likely doesn't exist, or her "success" is not related to the product being sold.
- **Don't click "HERE" in the PS:** Attackers often put a secondary link in a "P.S." section because users who are skeptical of the main link might click the "alternative" deal out of curiosity.
- **Don't use work emails for "deals":** Never sign up for personal "mentorships" or "bundles" using a corporate email address. This exposes the company to further "Marketing Spam" and potential data breaches.



3. REMEDIATION ROADMAP

Phase 1: Immediate Containment (0-24 Hours)

- **Block Identified Threats:** Add the domains discovered in our analysis (mm.mail.pl, takakasa.pl, itsamalielund.com) to the corporate "Block List."
- **Identify "Clickers":** Cross-reference mail logs to see if any employees clicked the links in these specific emails.
- **Mandatory Password Resets:** If a click is confirmed on Email 02 (The Loan Scam), the user must reset their credentials and initiate a "Security Review" of their account activity.

Phase 2: Technical Hardening (1-2 Weeks)

- **Enforce Multi-Factor Authentication (MFA):** Ensure that even if a password is stolen (via Case #001 or #002), the attacker cannot log in without a physical token or biometric check.
- **Banner Implementation:** Set up an "External Email" warning banner for all incoming mail that does not originate from a trusted corporate domain.
- **Link Sandboxing:** Implement a tool that "rewrites" links, scanning them for malicious content in real-time before the user's browser opens them.

Pro Tip: Employee Cheat Sheet: The "3-Second Rule"

Before clicking any link in an email, employees should ask these three questions:

1. **Am I Expecting This?** Did I apply for a loan? Did I enter a contest for a voucher?
2. **Does the Subject Match the Body?** (Like Email 01 where the subject was about "Rates" but the email was about "Holidays").
3. **Is there a "Fake" Deadline?** Does the email say I only have 2 hours or 1 minute to act?

4. CONCLUSION

The samples analyzed-ranging from personalized "Holiday Vouchers" to "Instant Loan Approval" and high-pressure "Marketing Bundles"- reveal a critical shift in attacker strategy.

We observed that **Email 02** and **Email 03** both achieved "PASS" ratings for SPF, DKIM, and DMARC. This proves that technical authentication is no longer a guarantee of safety. Attackers are now using legitimate infrastructure and professional configurations to bypass traditional spam filters.

The common thread across all attacks was the use of **cognitive triggers**:

- **Greed:** The lure of "free" money or massive discounts.
- **Urgency:** Artificial deadlines (2 hours, 24 hours) designed to bypass critical thinking.
- **Trust:** Using the recipient's real name and professional-looking layouts to mimic legitimate corporate or financial institutions.

Technical defenses like MFA and link sandboxing are mandatory, but they are not foolproof. This task highlights that **employee education** is the most effective defense. When users are trained to spot a mismatched subject line, a suspicious sender domain, or a "too good to be true" offer, the attacker's success rate drops to near zero.